OPEN GOVERNANCE STANDARD · V1.0 · MARCH 2026

The Sentinel Framework

A Standard for Agentic AI Governance

> *"Don't give AI a job. Give it a task. Know every token it spends. Put a human in the middle — not at the end."*
>
> **— Christopher Gyening, Architect · Sentinel Framework v1.0**

© 2026 Christopher Gyening / gyeningcorp
Licensed under Apache 2.0 · github.com/gyeningcorp/sentinel-framework
gyeningcorp.github.io/sentinel-framework

Table of Contents

The Problem with AI Governance Today — Intro

Pillar 1 — Token Accountability — P01

Pillar 2 — Human-In-The-Middle (HITM) — P02

Pillar 3 — RAG vs. LAG — P03

Pillar 4 — Least Privilege Agency — P04

Pillar 5 — Tasks Over Jobs — P05

Pillar 6 — Network Security Architecture — P06

Implementation Guide — 3 Phases to Compliance — IMPL

Compliance Checklist — CHECK

The Problem with AI Governance Today

Organizations are giving AI **jobs** — broad, vague mandates with wide access and no accountability trail. An AI that "handles customer support" has no defined scope, no audit trail, and no kill switch. When something goes wrong, no one can explain what happened, who authorized it, or how to prevent it next time.

The Sentinel Framework solves this. It is an open governance standard for deploying AI agents safely, accountably, and auditably — built for the era when AI doesn't just answer questions, it takes action.

This is not a product. It is a standard — like OWASP for web security, or RFC for internet protocols. It is free to use, open source, and designed to become the common language for AI governance across industries.

The Six Pillars

#	Pillar	One Line
1	Token Accountability	Every token is a decision. Audit the decisions.
2	Human-In-The-Middle	Humans don't just approve. They steer.
3	RAG vs. LAG	Memory for truth. Logs for drift.
4	Least Privilege Agency	AI gets a badge, not a master key.
5	Tasks Over Jobs	Atomic actions. Not open mandates.
6	Network Security Architecture	Where your AI lives determines what it can touch.

PILLAR 01

Token Accountability

The Audit Trail for AI Thought

The Problem

Traditional logging tells you *that* an AI spoke. Token Accountability tells you *how* it thought. A log entry that says "AI responded at 14:32" is useless when something goes wrong. You need to know what information it retrieved, how many reasoning steps it took, and whether its logic stayed on topic — or started drifting.

The Concept

Every token generated by an AI agent is tied to a **Budget Identity** — a traceable record of who initiated the task, what the scope was, how many tokens were budgeted vs. consumed, and whether the output was semantically meaningful or repetitive.

Key Metrics

Metric	What It Detects
Token velocity	Runaway loops, excessive reasoning
Semantic repetition	Hallucination spikes
Retrieval-to-generation ratio	Over-reliance on fabrication
Budget overrun %	Scope creep, prompt injection
Off-topic drift score	Goal misalignment

Red Flags

🚨 **Hallucination Spike** — Token velocity rises, but output confidence drops. The AI is generating without grounding.

🚨 **Prompt Injection Loop** — Token budget resets unexpectedly. A malicious instruction is trying to restart the agent's context.

🚨 **Semantic Collapse** — The last 20 tokens are nearly identical to the previous 20. The agent is stuck.

🔢 **REAL-WORLD TOOL: TOKENIZER**

TOKENIZER

is a free, open-source Chrome/Edge extension built by the same team behind Sentinel. It implements Pillar 1 in the browser — giving you real-time token counts for every AI conversation before you send it.

- Live token counting — see exactly how many tokens your prompt will consume
- Conversation mode — tracks running totals across System / User / Assistant turns
- Works everywhere — Claude, ChatGPT, Gemini, any AI interface in your browser
- Desktop app — standalone Windows app with local model support (Ollama, LM Studio, Jan)

Install: github.com/gyeningcorp/tokenizer

EXECUTIVE SUMMARY

Your AI has an expense report. Every decision costs something. Audit it the same way you audit financial spend — with line items, budgets, and alerts when something goes over.

PILLAR 02

Human-In-The-Middle (HITM)

Active Intervention, Not Passive Approval

The Problem

"Human-in-the-loop" is passive — a human reviews what the AI did after the fact. That's not governance. That's a signature on a document you didn't write. **Human-In-The-Middle (HITM)** means humans intercept, correct, and steer the AI during inference — before high-stakes actions are taken.

Two Modes

Mode 1: Gatekeeping

Critical actions require a cryptographic handshake from a verified human before executing. Not a checkbox — a signed token proving a specific human authorized a specific action at a specific time.

Actions that always require HITM: Financial API calls · Data deletion · External communications · Account creation · Credential access

Mode 2: Correction Vectors

The human doesn't just say "Yes" or "No." They inject a Correction Vector — a semantic nudge that steers the model's next output toward the intended goal.

Why "In-The-Middle" Matters

```
Traditional HITL:
[AI generates] → [AI acts] → [Human reviews]   ← Too late.

HITM:
[AI generates] → [Human intercepts] → [Human corrects] → [AI acts]
                        ↑ Right here. This is the moment.
```

EXECUTIVE SUMMARY

Your CFO doesn't approve budgets after the money is spent. Don't approve AI actions after they've been taken. Put the human in the middle — not at the end.

PILLAR 03

RAG vs. LAG

Memory for Truth. Logs for Drift.

Two Tools, Two Problems

RAG (Retrieval-Augmented Generation) answers: What does the AI know? It grounds outputs in verifiable, retrieved facts and creates a pre-action audit record.

LAG (Log-Augmented Governance) answers: Where is the AI heading? It monitors the trajectory of decisions across an entire session and kills the session if it drifts from the goal.

The Kill Switch

Delta	Status	Action
0.00–0.15	On track	Continue
0.16–0.35	Drifting	Alert human, log warning
0.36–0.60	Off course	Pause, require HITM approval
0.61+	Dangerous	Terminate session immediately

The kill happens **before the action**, not after. You are not cleaning up a mess. You are preventing one.

> **EXECUTIVE SUMMARY**
>
> *Every plane has a GPS and a black box. GPS tells you where you are. The black box proves what happened. LAG is your black box — and it can pull the ejection handle before the crash.*

PILLAR 04

Least Privilege Agency

AI Gets a Badge, Not a Master Key

Ephemeral Scoped Roles (ESRs)

Every agent receives a time-limited, task-specific permission token. Not a user account — an ESR that expires when the task ends. Permissions are defined as **verbs**, not roles.

Read	Write	The Rule
read:email	send:email	Never give send without HITM
read:database	write:database	Writes require task justification
read:files	delete:files	Delete requires human approval always

Multi-Agent Trust

No agent can have more permissions than its parent. No agent can grant permissions it doesn't have. Every multi-agent spawn requires a new human-signed ESR.

> **EXECUTIVE SUMMARY**
>
> *Contractors get key cards — not the building access code. Your AI is a contractor. Define exactly which doors it can open, for how long, and make sure it can't copy the key.*

PILLAR 05

Tasks Over Jobs

Atomic Actions. Not Open Mandates.

The Job Fallacy

The most dangerous words in AI deployment: "The AI handles our [X]." Jobs are broad, vague, and unauditable. When something goes wrong, you can't explain what happened. **Tasks create accountability. Jobs create liability.**

❌ Job	✅ Task
"Manage customer support"	"Summarize the 5 oldest open tickets"
"Handle our email"	"Draft a reply to email ID #4521"
"Run the data pipeline"	"Export Q1 sales data to CSV"
"Manage social media"	"Generate 3 caption options for this image"

Stateless Agency

Once a task is complete, the agent's memory and access are wiped. This prevents Long-term Goal Alignment Drift — where an AI begins making decisions that protect its own continued existence to finish a long-running job.

> **EXECUTIVE SUMMARY**
>
> *You hire a plumber to fix a pipe — not to manage your building's infrastructure. The job is too big, too vague, and too dangerous to delegate. The task is clear, auditable, and done in 20 minutes.*

PILLAR 06

Network Security Architecture

Where Your AI Lives Determines What It Can Touch

LAN AI vs. Internet AI — The Fundamental Split

The most important architectural decision in AI deployment: does this agent operate inside your network, or does it touch the internet? These are not the same risk profile.

```
THE INTERNET
       |
  ┌────▼────┐
  | FIREWALL |
  └─────────┘
       |
  ┌────▼──────────────┐
  |   DMZ (AI ZONE)   |  ← Internet-facing AI lives HERE
  |   External Agents |
  |   API Gateway     |
  |   RAG / Vector DB |
  └───────────────────┘
       |
  ┌────▼──────────────┐
  |  INTERNAL FIREWALL |
  └───────────────────┘
       |
  ┌────▼──────────────┐
  |  LAN (SECURE ZONE) |  ← Internal AI lives HERE
  |  Internal Agents   |
  |  Databases         |
  |  Financial Systems |
  └───────────────────┘
```

The Golden Rule

An AI agent that touches the internet should NEVER have direct access to internal systems. All cross-zone communication must go through an authenticated, logged API gateway.

4-Zone Network Model

Zone	Name	What Lives Here	Internet
1	Public Edge	Load balancers, WAF, CDN	Direct
2	AI DMZ	Internet agents, API gateway, vector DB	Outbound (allowlisted)
3	Internal AI	Internal agents, HITM gateway	None
4	Core Systems	Databases, financial, auth	None

Prompt Injection as a Network Threat

When an AI retrieves content from the internet, that content can contain **prompt injection attacks** — malicious instructions embedded in data that try to hijack the agent. Network-level defenses include content inspection gateways, egress filtering to pre-approved domains only, and data diodes for maximum isolation.

On-Premise vs. Cloud

Model	Best For	Key Rule
On-Premise (LAN AI)	Regulated industries, sensitive data	Full control, no data leaves building
Cloud AI	Public-facing, research agents	DMZ rules apply at VPC/subnet level
Hybrid (Recommended)	Most enterprises	Sensitive on-prem, public in cloud DMZ

EXECUTIVE SUMMARY

In the 90s, companies put web servers next to file servers. Hackers loved it. We learned — we built DMZs. Now AI agents are making the same mistake. The fix is the same: put a wall between what faces the world and what holds your secrets.

Implementation Guide

Three Phases to Compliance

Phase 1 — Foundation (Weeks 1–4)

- Audit every AI tool in use — what data can it access? What actions can it take?
- Classify each workflow as Job (broad) or Task (scoped) — fix the jobs
- Assign a human owner to every AI workflow
- Remove unused permissions from all AI tools
- Add a human approval step before any AI sends an external communication
- Start logging all AI interactions

Phase 2 — Governance Layer (Months 2–3)

- Deploy token monitoring with budget limits (Pillar 1)
- Implement HITM gates on all critical actions (Pillar 2)
- Issue scoped, time-limited permission tokens per agent (Pillar 4)
- Isolate internet-facing AI to DMZ network segment (Pillar 6)

Phase 3 — Sentinel Standard (Months 4–6)

- Deploy full RAG/LAG with automated kill-switch (Pillar 3)
- Complete task decomposition — eliminate all "job" workflows (Pillar 5)
- Implement 4-zone network architecture (Pillar 6)
- Run compliance checklist and self-certify

Maturity Model

Level	Name	Description
0	Unmanaged	AI tools deployed with no governance

1	Aware	AI inventory exists; basic logging in place
2	Controlled	Token budgets, HITM gates, scoped permissions
3	Governed	Full RAG/LAG, task decomposition, stateless agents
4	Sentinel Compliant	All six pillars implemented and auditable

Compliance Checklist

Score each pillar and total your score for certification level.

Pillar 1 — Token Accountability (6 points)

- ☐ All LLM API calls logged with token counts
- ☐ Logs include task ID, initiator, and timestamp
- ☐ Token budgets defined per task type
- ☐ Alerts fire when spend exceeds 2x budget
- ☐ Logs retained for minimum 90 days
- ☐ Semantic drift / repetition detection active

Pillar 2 — Human-In-The-Middle (6 points)

- ☐ Critical actions formally defined and documented
- ☐ HITM gates enforced before all critical actions
- ☐ HITM uses cryptographic sign-off
- ☐ Correction Vectors can be injected by human
- ☐ Deny-by-default enforced on timeout
- ☐ HITM decisions logged in audit trail

Pillar 3 — RAG vs. LAG (6 points)

- ☐ RAG sources cited before consequential actions
- ☐ Environment state verified and logged pre-action
- ☐ Goal Vectors defined for all agent workflows
- ☐ LAG drift monitoring active
- ☐ Kill-switch thresholds defined and tested
- ☐ LAG logs stored alongside token logs

Pillar 4 — Least Privilege Agency (6 points)

- ☐ All agents use scoped, time-limited permission tokens
- ☐ No agent has more permissions than required
- ☐ All agent identities tied to a human initiator
- ☐ Permission tokens expire on task completion
- ☐ Multi-agent permission inheritance controlled
- ☐ Permission grants logged in audit trail

Pillar 5 — Tasks Over Jobs (6 points)

- ☐ All workflows defined as task lists, not job descriptions
- ☐ Each task has an explicit forbidden actions list
- ☐ Agent context wiped after each task
- ☐ Tasks follow Sentinel Task Specification format
- ☐ Token budgets enforced per task
- ☐ No agent has persistent access across unrelated tasks

Pillar 6 — Network Security (8 points)

- ☐ Internet-facing AI isolated in DMZ
- ☐ No direct connections between internet AI and internal databases
- ☐ Egress filtering — AI can only call pre-approved endpoints
- ☐ API gateway with auth, rate limiting, and logging between zones
- ☐ Content inspection / prompt injection detection at ingress
- ☐ LAN AI and internet AI on separate network segments
- ☐ All inter-zone traffic encrypted (mTLS)
- ☐ Network flows logged to SIEM

Scoring

Score	Level	Status
0–12	Level 0–1	Not compliant

13–24	Level 2	Partially compliant
25–32	Level 3	Mostly compliant
33–37	Level 4	Compliant
38	Level 4	Fully Sentinel Compliant ✅

© 2026 Christopher Gyening / gyeningcorp · Apache 2.0 · github.com/gyeningcorp/sentinel-framework